

CORTORA

Handling Customer Personal Data in Operational Work

Document ID	Version	Owner	Classification	Effective	Review cycle
COR-SEC-031	2.0	Security & Legal	Internal	01 September 2026	Annual

This policy defines how Cortora employees and internal AI systems, including OpsPilot, must handle customer personal data, payment metadata, and other sensitive information encountered during operational work. It applies alongside applicable data protection law and does not replace legal advice on a specific matter.

1. Categories of Data

Category	Examples	Sensitivity
Identity data	Name, date of birth, account identifiers	Standard
Contact data	Email address, phone number, shipping/billing address	Standard
Payment metadata	Card fingerprint, last four digits, transaction identifiers, authorization results	Elevated — never full card numbers, which Cortora does not store
Order and behavioural data	Order history, browsing history, support interactions	Standard
Risk and investigation data	Fraud indicators, device fingerprints, risk scores	Elevated
Special category data	Any health, biometric, or similarly sensitive data incidentally disclosed by a customer	High — minimize collection and retention

2. Principle of Least Privilege

- Access customer data only to the extent necessary for the specific case you are working on.
- Do not browse customer accounts, order histories, or payment records without a legitimate, documented business reason tied to an active case.
- When a case references more customer information than necessary to resolve it, avoid reproducing the excess information in case notes, AI prompts, or communications with other employees.
- Do not copy customer data into personal devices, personal cloud storage, or personal messaging applications under any circumstance.

3. Data Handling When Using OpsPilot

- Provide OpsPilot only the identifiers and details necessary to investigate the specific case at hand.
- Do not paste unrelated customer records, bulk exports, or full account histories into a prompt when only a single order or transaction is relevant.
- Treat any customer data that OpsPilot retrieves through approved tools as subject to the same handling rules as data retrieved manually — it does not become less sensitive because an AI system produced it.

- Do not ask OpsPilot to compile cross-customer reports or comparisons unless this is an explicitly approved part of your role and business justification.

4. Retention

Case records, including the evidence gathered and communications with the customer, are retained according to Cortora's data retention schedule maintained by Technology & Data, which reflects both operational need and applicable legal retention requirements. Employees must not manually delete case data to shorten its retention period, and must not extend retention by exporting or duplicating data outside approved systems.

5. Data Subject Requests

Customers may request access to, correction of, or deletion of their personal data. Such requests must be routed to the designated privacy contact rather than handled directly within a support case, since they involve legal timelines and verification steps beyond standard case handling. A Support Agent receiving such a request should acknowledge it, avoid taking any deletion action themselves, and escalate immediately.

6. Sharing Data with Third Parties

- Data may be shared with fulfillment and carrier partners only to the extent necessary to deliver an order.
- Data may be shared with payment providers only to the extent necessary to process a transaction or refund.
- Data must not be shared with any other third party, including on a customer's own request, without going through the designated privacy and legal review process.
- Internal AI systems, including OpsPilot, must not be given tool access that would transmit customer data to an external system that has not been through this review process.

7. Handling Suspected Data Exposure

If an employee suspects customer data has been exposed, accessed inappropriately, or sent to the wrong recipient, they must report it immediately through the designated security channel rather than attempting to quietly correct it. Early reporting materially affects Cortora's ability to limit harm and meet any applicable legal notification obligations.

8. Untrusted Content Containing Personal Data

External content such as customer messages, uploaded files, or webpages may contain personal data about third parties who are not the requesting customer. This data should be treated with the same care as any other personal data and should not be repeated back, stored, or shared beyond what is necessary to resolve the case at hand.

9. Related Documents

- Employee Handbook & Internal Systems Guide — general access and account security obligations.
- Customer Support SOP — case-handling communication standards.
- Fraud & Risk Policy — handling of investigation-specific data.

Synthetic environment notice: Cortora, its employees, customers, policies, and operational records are fictional and created solely for the OpsPilot engineering project.